

Security+ 4.8 · Incident Planning

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 4.8 — Incident Planning (6:50)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Tabletop exercise (jogo fictício — treina decisores); simulation (falta simulada); RCA (root cause analysis — o porquê real); documentation; playbook por tipo (ransomware/phishing).

Highlights que a prova cobra

- Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real
- RCA: a causa RAIZ (o porquê), não o sintoma

Dicas de prova & Cenários Típicos

- 'simulated exercise without real impact'=tabletop

Cenário clássico de exame: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabletop.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 4.8 — Incident Planning)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. De acordo com o NIST, qual é a primeira fase do ciclo de resposta a incidentes?

- A)** Detecção e Análise
- B)** Preparação
- C)** Contenção
- D)** Recuperação

2. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real...

3. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'RCA: a causa RAIZ (o porquê), não o sintoma'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RCA: a causa RAIZ (o porquê), não o sintoma...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'simulated exercise without real impact'=tabletop'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'simulated exercise without real impact'=tabletop...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: "empresa joga o cenário de ransomware em conversa pra testar resposta'=tabletop.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabl...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'RCA: a causa RAIZ (o porquê), não o sintoma'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: RCA: a causa RAIZ (o porquê), não o sintoma...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: "simulated exercise without real impact'=tabletop'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'simulated exercise without real impact'=tabletop...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: "empresa joga o cenário de ransomware em conversa pra testar resposta'=tabletop.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabl...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Incident Planning): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 4.8), um analista avalia o seguinte requisito técnico: 'Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Preparação.

✓ **Por que está certa:** A alternativa correta é 'Preparação'. De acordo com o NIST SP 800-61 (Computer Security Incident Handling Guide), o ciclo de resposta a incidentes é composto por quatro fases: Preparação; Detecção e Análise; Contenção, Erradicação e Recuperação; e Atividades Pós-Incidente. A primeira fase, Preparação, é fundamental e ocorre antes que qualquer incidente aconteça. Ela envolve estabelecer políticas, procedimentos, treinamento de equipe, aquisição de ferramentas (SIEM, EDR, forense), definição de canais de comunicação e criação de planos de resposta. Sem uma preparação adequada, as fases subsequentes são comprometidas. O CompTIA Security+ enfatiza que a preparação é a base para uma resposta eficaz e que deve ser contínua, incluindo exercícios e simulações.

✗ **Por que as outras estão erradas:**

- *Detecção e Análise:* Esta é a segunda fase do ciclo de resposta a incidentes do NIST. Ela ocorre após a preparação e envolve monitorar, identificar e validar a ocorrência de um incidente, além de analisar seu escopo e impacto. Embora seja crucial, não é a primeira fase, pois depende de recursos, procedimentos e treinamento estabelecidos na preparação. A detecção e análise só podem ser eficazes se houver uma base preparada para coletar logs, correlacionar eventos e interpretar alertas.
- *Contenção:* A contenção faz parte da terceira fase do ciclo (Contenção, Erradicação e Recuperação). Seu objetivo é limitar o dano e impedir a propagação do incidente, isolando sistemas afetados. No entanto, a contenção só pode ser executada depois que o incidente foi detectado e analisado, e depende de planos e recursos definidos na fase de preparação. Portanto, não é a primeira fase, mas sim uma etapa reativa que ocorre durante o incidente.
- *Recuperação:* A recuperação também integra a terceira fase do ciclo, após a contenção e erradicação. Ela consiste em restaurar sistemas e serviços afetados ao estado normal de operação, validar que a ameaça foi eliminada e monitorar para garantir que não haja reinfeção. Assim como a contenção, a recuperação é uma etapa posterior à detecção e análise e depende de uma preparação prévia, como backups e planos de continuidade. Não é a primeira fase do ciclo de resposta a incidentes.

2) D — Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) B — Implementar a solução correspondente: RCA: a causa RAIZ (o porquê), não o sintoma....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): RCA: a causa RAIZ (o porquê), não o sintoma.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: 'simulated exercise without real impact'=tabletop....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): 'simulated exercise without real impact'=tabletop.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) B — Implementar a solução correspondente: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabl....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabletop..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: RCA: a causa RAIZ (o porquê), não o sintoma....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): RCA: a causa RAIZ (o porquê), não o sintoma.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) C — Implementar a solução correspondente: 'simulated exercise without real impact'=tabletop....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): 'simulated exercise without real impact'=tabletop.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) B — Implementar a solução correspondente: 'empresa joga o cenário de ransomware em conversa pra testar resposta'=tabl....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): 'empresa joga o cenário de ransomware em conversa pra testar

resposta'=tabletop..

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) C — Implementar a solução correspondente: Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real....

✓ Por que está certa: Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 4.8 (Incident Planning): Tabletop: o 'jogo de mesa' do incidente — treina sem impacto real.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.